



PAMIBIA UNIVERSITY
OF SCIENCE AND TECHNOLOGY

SAS821S LAB 3

Threat Intelligence, Text Mining, Network Propagation Simulation and
Predictive Security Intelligence

Mwandingi Marshall
215103238



SEPTEMBER 18, 2026

https://github.com/mwandingim/215103238_Mwandingi_SAS821S_Lab_3.git

Initial Assessment and Competing Hypotheses

Initial Assessment

Erongo Grid Services faces a likely but not yet fully confirmed operational security risk relating to vendor remote access pathway into the OT environment. The most worrying evidence is the sequence of event on 17 October 2026, failed and then successful VPN access from a new external source, execution of an unsigned remote support binary, DNS queries to desert-sync.example, authentication to the OT jump server outside an accepted window, an EDR blocked credential dumping attempt, access to an engineering workstation, PLC subnet scanning, historian tag enumeration, and blocked Modbus function activity against PLC-SUB-01. The supplied threat intelligence also defines a Southern African energy utility campaign linked to compromised vendors, Sandstorm Loader, DNS command and control and movement from vendor systems toward OT engineering assets.

The instant operational decisions which EGS must do are to determine whether this is a honest OT intrusion attempt, whether the action was caused by benign vendor work or misconfiguration, or whether external intelligence coincidentally resembles normal internal activity. EGS must decide whether to keep the vendor access path banned, isolate or rebuild affected assets, improve OT monitoring, block and hunt for matching indicators and brief operational leadership without claiming successful PLC manipulation or operational impact. At this stage, the evidence supports attempted intrusion and attempted OT reconnaissance or write activity, but it does not prove successful PLC configuration change, control system manipulation or physical operational disruption.

Competing Hypotheses

Genuine OT intrusion: This hypothesis argues that the vendor remote access pathway was used for an unlawful intrusion into the EGS OT environment. It would be strengthened if later dataset and log analysis confirms matching supplied indicators, unauthorised VPN access, suspicious PowerShell execution, credential access attempts, movement to OT-JUMP-01 and ENG-WS-01, PLC scanning, or blocked Modbus write activity. It would be weakened if the activity is fully explained by approved vendor maintenance and no malware, abnormal authentication, or suspicious OT behaviour is found.

Benign vendor activity or misconfiguration. This hypothesis suggests that the events were caused by authorised maintenance, testing, configuration error, or another non-malicious activity. It would be strengthened by a matching work order, vendor confirmation, valid MFA approval, and engineering records explaining the OT activity. It would be weakened by evidence of activity outside the approved window, unsigned tool execution, credential-dumping alerts, suspicious DNS traffic, or vendor inability to explain the session.

Intelligence coincidence or false-positive correlation. This hypothesis proposes that the internal activity only appears related to the external campaign and may be a coincidence or false positive match. It would

be strengthened if the supplied IOCs do not appear in internal logs and the activity is shown to be routine vendor behaviour. It would be weakened by exact IOC matches, close timing with the reported campaign and a clear event chain from VPN access to OT reconnaissance.

Intelligence Cycle and Quality Plan.

Priority Intelligence Requirements

1. Was the 17 October vendor VPN session authorised maintenance activity or unauthorised intrusion using the vendor remote access path?
2. Did the suspicious activity progress from VENDOR-LT-07 to OT-JUMP-01 and ENG-WS-01 in a way that indicates credential access, lateral movement or attacker controlled execution?
3. Was there reconnaissance or attempted manipulation of PLC-SUB-01 and other OT assets, including historian enumeration, PLC subnet scanning or blocked Modbus function activity?
4. Do internal indicators match the supplied threat intelligence reports and IOCs for the Southern African energy utility campaign, including Sandstorm Loader, desert-sync.example, 203.0.113.77, and 198.51.100.44?

Mapping Supplied Sources to the Intelligence Cycle

Direction: The decision problem will be used to set the investigation focus, whether vendor access was exploited, OT assets were reached and if the supplied campaign intelligence applies. The output is a clear set of PIRs, collection priorities and escalation limits.

Collection: The collection stage gathers VPN, MFA, EDR, DNS, firewall, OT-IDS, historian, engineering workstation and vendor evidence. This creates a combined evidence set showing who connected, what tools ran, which OT systems were accessed and if supplied indicators appear internally.

Processing: Processing converts the raw evidence into working intelligence by normalising timestamps, removing duplicates, obtaining indicators and linking related events. The result is a clean incident timeline and indicator matrix for comparing the competing hypotheses.

Analysis: Analysts assess if the evidence best supports genuine intrusion, benign vendor activity or a false positive correlation. This stage produces a reasoned verdict with confidence level, key evidence, gaps and recommended operational actions.

Dissemination: Dissemination provides tailored intelligence products to SOC responders, OT engineers, leadership and the vendor. Technical teams receive indicators and containment details, while decision makers receive risk, confidence and action options.

Feedback: Feedback captures decision maker questions, SOC findings, engineering validation and vendor responses. These inputs refine the PIRs, update hypotheses and retake collection against unresolved gaps.

Quality Risks and Mitigation Plan

Veracity. The threat intelligence, model outputs and alerts can be lacking or synthetic. Cross checking IOCs against internal telemetry, event IDs, asset context and vendor explanations is done before making operational claims.

Timeliness. Old indicators or delayed logs may misrepresent the current risk. I will preserve original timestamps, normalise evidence to Namibia local time and separate observed activity from later reporting.

Duplication. Repeated alerts or reports could falsely increase confidence. I will deduplicate records by report ID, IOC ID, event ID, timestamp, host, source and indicator value before counting evidence.

Bias. Analysts may over-focus on the intrusion hypothesis because the campaign reporting appears to match the incident. I will maintain competing hypotheses and record evidence that weakens each one.

Access control. Security, vendor and OT data may contain sensitive operational details. I will apply need-to-know access and protect raw logs, hashes and infrastructure details.

Operational context. Blocked OT events, scans or historian reads do not automatically prove manipulation or outage impact. I will validate findings with OT engineers, maintenance schedules and change records.

Evidence Integrity and Analytic Caution

The supplied evidence retained unchanged and the analysis is performed on working copies or data frames. The executable notebook records the SHA-256 comparison against *SHA256SUMS.txt*, the fixed seed 8213026 and the exact software and library versions used. This makes each result traceable to its source and allows the workflow to be rerun from top to bottom.

External IOCs and model probabilities are preserved as decision support evidence not as facts by themselves. A matched IP address, domain or hash increases suspicion only if it aligns with internal telemetry, timing, affected assets and operational context. Also text classifier scores, predictive risk probabilities and simulation probabilities should support prioritisation, escalation and control comparison, but they should not be labelled as proof of successful compromise, PLC manipulation or operational impact.

Decision-Makers and Intelligence Products

SOC and incident response team: They need a technical indicator package containing event IDs, affected hosts, IOCs, detection logic, containment steps and hunt priorities. The purpose is to support investigation, containment, host triage, log review and ongoing monitoring.

OT engineering and operations managers: These decision-makers need an operational impact note covering PLC-SUB-01, ENG-WS-01, OT-JUMP-01, historian activity, blocked OT commands and safety

or availability constraints. This helps them decide whether assets should be isolated, monitored, rebuilt or kept in operation under compensating controls.

CISO: The CISO needs a security risk brief summarising the confidence level, likely intrusion path, matched intelligence, containment status, unresolved PIRs and required resources. This supports risk acceptance, incident escalation, vendor access decisions and cyber response coordination.

Chief Operations Officer and executive leadership: Executive leadership needs a concise intelligence brief explaining the incident conclusion, operational risk, evidence limitations, priority actions and 90-day improvement measure. This enables proportionate leadership decisions without overstating technical evidence or creating unnecessary operational disruption.

Vendor security or contact team: The vendor team needs an evidence request and coordination note covering maintenance approval, source device validation, account activity and remote support tool legitimacy. This helps confirm whether the vendor activity was authorised and whether vendor access should remain suspended or be restored safely.

Text Mining and Threat-Intelligence Prioritisation

Text Preparation and Exploratory Analysis

The text-mining stage uses the labelled historical reports in `egs_text_training.csv` and the unlabelled investigation reports in `egs_text_investigation.csv`. The primary modelling input is the combination of each report title and report text field, while appropriate label is used only as the supervised target for training. The data dictionary confirms that report text contains unstructured intelligence and relevant label represents historical analyst judgement, the label is not used as a predictor. The reproducible workflow below checks missing values, duplicates, source and date distributions, and class balance before fitting the classifier.

Text preparation uses lower casing, punctuation insensitive tokenisation, TF-IDF weighting, English stop-word removal, and one and two word n-grams. Unigrams capture individual security terms such as Modbus, PowerShell, vendor, DNS and ransomware, while bigrams preserve operational phrases such as vendor access, OT jump, DNS tunnelling and Modbus scanning.

Dataset loading and data quality assessment

The labelled historical training set contains 2,000 reports and the unlabelled investigation set comprises 171 reports. Before text modelling the data was checked for missing values, duplicated rows, duplicated report IDs, source coverage and publication date coverage. No missing values or duplicate rows were found in either dataset also no duplicated report id values were identified.

Dataset	Rows	Missing values	Duplicate rows	Duplicate report IDs	Earliest date	Latest date
Training	2000	0	0	0	2025-01-01	2026-09-12
Investigation	171	0	0	0	2025-01-03	2026-10-17

Table B1: Dataset Quality Assessment Summary

Class balance in the historical training data

The training set contains 1,253 reports labelled not relevant (0) and 747 labelled relevant (1), equivalent to 62.6% and 37.4%, respectively. This was treated as a moderate imbalance. Accuracy alone could hide missed relevant reports, the classifier interpret mainly through recall and false negative rate alongside precision and F1 score.

Historical relevance label	Number of reports	Percentage
0 – Not relevant	1253	62.6%
1 – Relevant	747	37.4%
Total	2000	100.0%

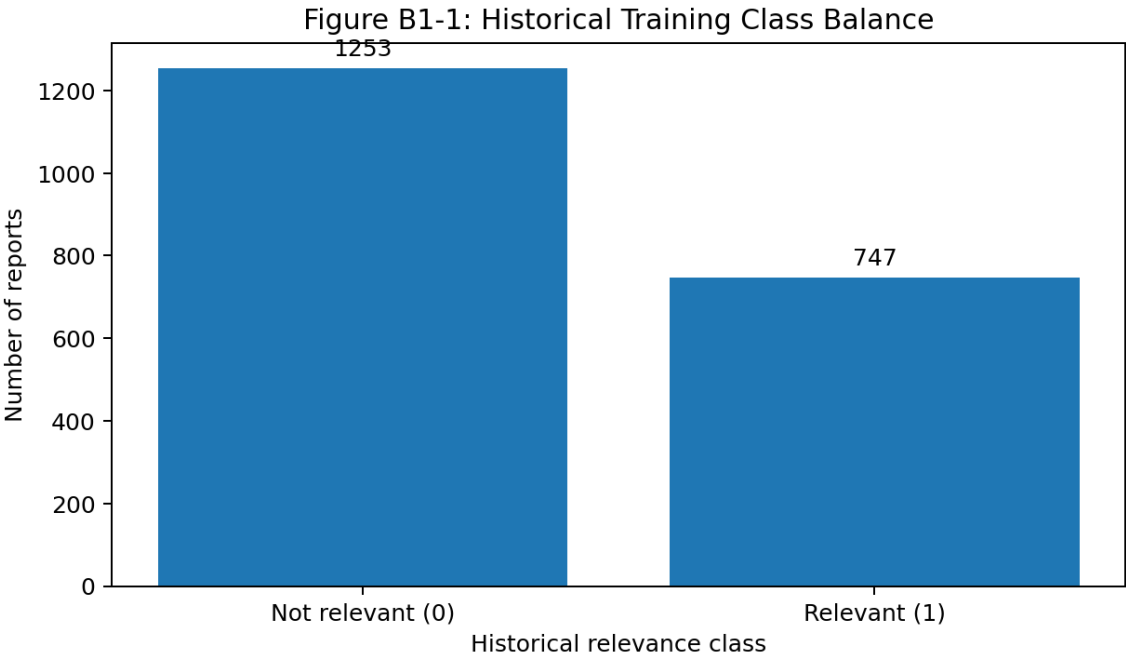


Table B1-1 Historical Training Class Balance

Source and publication date distribution

Training reports have distributed across five principal sources, whereas the investigation data comprises of seven source labels. This distribution helps detect source concentration and prevents the analysis from if all intelligence sources contribute equally.

Source	Training	Training %	Investigation	Investigation %
CERT-NA	391	19.6%	29	17.0%
Commercial Intelligence	422	21.1%	30	17.5%

OT Security Vendor	0	0.0%	1	0.6%
Open-source Research	367	18.4%	34	19.9%
Regional Energy ISAC	0	0.0%	1	0.6%
Regional ISAC	381	19.1%	40	23.4%
Vendor Advisory	439	21.9%	36	21.1%

Figure B1-2: Report Distribution by Source

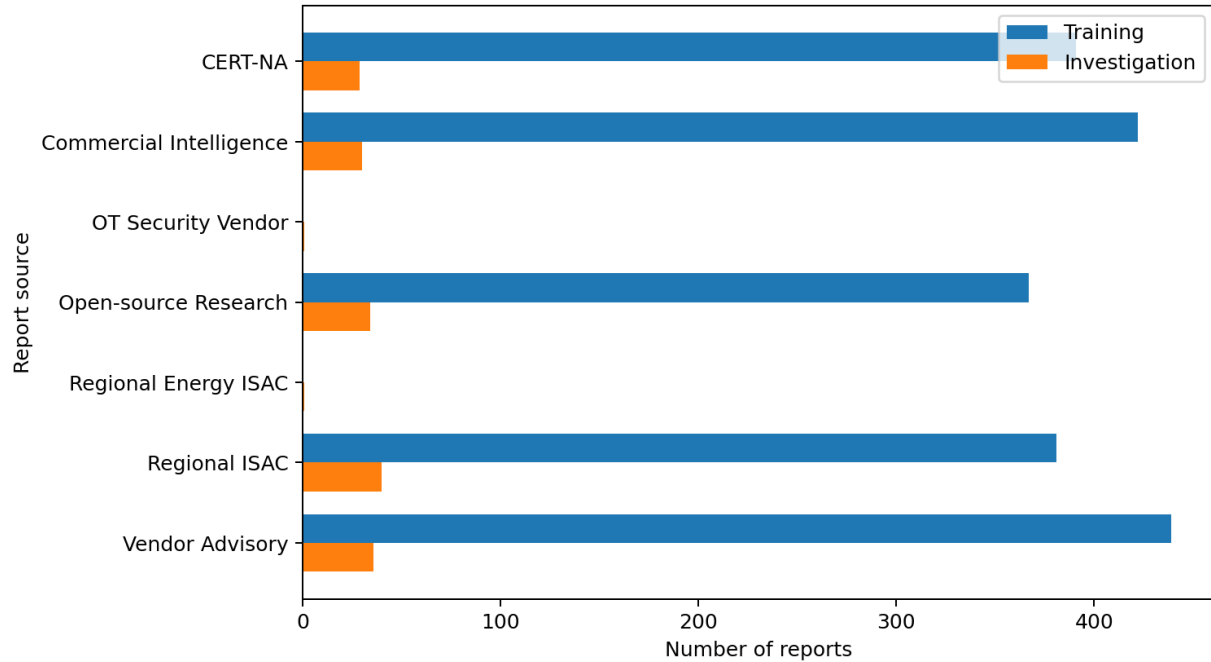


Table B1-2: Report Distribution by Source

Publication year	Training reports	Investigation reports
2025	1173	96
2026	827	75

Table B1-3: Publication Year Distribution

Reproducible text-preparation pipeline

The primary text input is the combination of report title and report_text. The relevant_label field is used only as the supervised training target and is not included as a predictor.

Step	Operation	Reproducible treatment
1	Combine fields	Concatenate title and report_text for each report.
2	Normalise	Convert text to lower case and use punctuation-insensitive processing.
3	Tokenise	Split the cleaned text into individual word/token units.

4	Stop-word handling	Remove common English stop words that add little security-specific information.
5	N-grams	Use unigrams and bigrams (1–2 word sequences) to retain individual terms and security phrases.
6	TF-IDF	Transform the cleaned text into weighted numerical features for classification.

Table B1-4: Reproducible Text-Preparation Pipeline

Unigrams capture individual security terms such as vendor, OT, scanning and PowerShell, while bigrams preserve operational phrases such as vendor access and OT jump. TF-IDF weights informative terms more strongly within the report collection. These choices are suitable because security relevance depends on combinations of techniques, actors, affected sectors and operational context rather than generic sentiment.

Exploratory TF-IDF terms

As an additional exploratory check, TF-IDF was calculated on the historically relevant training reports. The terms and phrases below provide an interpretable view of vocabulary associated with the relevant class.

Term / phrase	Mean TF-IDF
vendor	0.0677
industrial	0.0598
ot	0.0528
example	0.0525
actor	0.0502
campaign	0.0495
activity	0.0487
infrastructure	0.0473
observed	0.0463
vendor access	0.0455

Table B1-5: Exploratory TF-IDF Terms for Relevant Reports

IOC and Entity Extraction and Operational Relevance

I used a transparent extraction routine for IPv4 addresses, domains, URLs, SHA-256 hashes, named threat actors and malware or tools. I chose pattern-based extraction because the required entities have recognisable formats and the results can be checked directly against the source reports. The output is saved as *extracted_iocs.csv* with the required fields *report_id*, *entity_type*, *entity_value* and *analytical_relevance*.

IOC matches were checked for confidence, recency and context. High confidence means a direct IOC-feed match; medium confidence means a plausible indicator requiring validation.

Report	Entity	Type	IOC	Confidence	Relevance
RPT9001	203.0.113.77	IPv4	IOC9001	High	Vendor remote access
RPT9001	maintenance-check.example	Domain	IOC9005	Medium	Credential lure
RPT9002	desert-sync.example	Domain	IOC9002	High	C2/DNS activity
RPT9002	198.51.100.44	IPv4	IOC9003	High	Suspicious TLS destination
RPT9004	8e50b5f71c8efa22abe51646264f41367451d4acc42134c8c2b787c3190bc393	SHA-256	IOC9004	High	Sandstorm Loader
RPT9003	Modbus reconnaissance	OT technique	—	Context	Possible OT movement
RPT9001	Kalahari Jackal	Threat Actor	—	Context	Vendor remote-access abuse

Table B2-1: Extracted IOCs and Operational Relevance

Finding: RPT9001–RPT9005 and IOC9001–IOC9005 provide multiple related indicators. The pattern supports a credible attempted vendor-to-OT intrusion, but the IOCs require internal telemetry corroboration.

Recency: IOC currency was assessed using the IOC feed's available timing information together with the report publication dates; older indicators were treated as historical context rather than current proof of activity.

Generic sentiment alone is not dependable for security triage because neutral wording can define high risk technical actions, while critical wording can be label an unverified or low risk event. The adversarial results show that changes in wording can alter model probability without changing the underlying security meaning.

Adversarial testing measured probability changes between the original and modified statements. ATX01 decreased by 0.1159 (15.29%), ATX02 by 0.2481 (29.41%), ATX03 by 0.1872 (25.46%), and ATX04

by 0.1880 (24.38%). ATX05 expanded by 0.1126 (18.99%) pointing that paraphrasing does not always lower the model score.

Investigation scoring: `egs_text_investigation.csv` was scored and the 15 highest-probability reports were exported to `top_15_relevant_reports.csv`. The ranking is an analyst triage aid and is not proof of malicious activity.

Model results: confusion matrix = `[[249, 2], [5, 144]]`. Accuracy = 0.9825, precision = 0.9863, recall = 0.9664, F1-score = 0.9763, and false-negative rate = 0.0336. Recall and false negative rate are vital because a missed relevant report can delay investigation of a possible critical infrastructure threat.

A TF-IDF logistic-regression classifier was trained using an 80/20 stratified train/test split with fixed seed 8213026. The model uses lower-case text, English stop-word removal, unigrams and bigrams, with minimum document frequency of 2. A 0.50 probability threshold was used for evaluation.

Text Classifier and Adversarial Language

Metric	Result
Accuracy	0.9825
Precision	0.9863
Recall	0.9664
F1-score	0.9763
False-negative rate	0.0336
Confusion matrix	<code>[[249, 2], [5, 144]]</code>

Table B3-1: Text Classifier Performance Metrics

Network Propagation Simulation and Control Comparison

Simulation Model Design

The simulation addresses PIR-03: how far a compromise originating at VENDOR-LT-07 could propagate through the IT/OT topology under current and improved controls. The model represents the supplied network as a directed graph. Each asset is a node and each directed topology edge represents a possible movement path. Base transmission probabilities come from the supplied topology, while host susceptibility comes from the host-security-posture data. VENDOR-LT-07 is the initial infected node. The graph therefore represents possible propagation paths rather than guaranteed compromise.

Variable	Implementation
Edge probability	The supplied base transmission probability is adjusted by the control factors in each scenario.
Host susceptibility	Each asset uses its supplied susceptibility value as a measure of how likely the target is to become infected.
Time step	Propagation occurs in discrete synchronous steps. Newly infected assets can attempt propagation in the next step.
Infection state	Each asset is either susceptible/uninfected or infected. An infected asset remains infected for the remainder of the run.
Stopping condition	A run stops when no new assets are infected or when the maximum 30-step simulation horizon is reached.
Random seed	Seed 8213026 is used for reproducibility, with independent reproducible random streams for the scenarios.

Table C1-1: Simulation Model Variables and Implementation

Simplifying assumptions:

- Propagation occurs only through the supplied directed topology.
- Transmission probabilities are synthetic teaching parameters and are not measured real world attack probabilities.
- Host susceptibility remains persistent during a unique simulation run.
- Propagation is probabilistic compromise of one asset does not certainly compromise every connected asset.
- Scenario controls change propagation and susceptibility according to the supplied scenario factors.
- The initial compromise is narrow to VENDOR-LT-07.

Outcomes that are selected translate directly into operational decisions. Whether propagation reaches OT or the Safety zone, how many critical and total assets are infected on average the median number of simulation steps before OT is reached and the 95th percentile of total infected assets as the high spread

measure. Together these show both typical impact and a credible upper-tail outcome when comparing patching, segmentation and rapid isolation.

Monte Carlo Simulation and Control Comparison

A Monte Carlo simulation was run for 1,000 iterations for each scenario. Every run began with VENDOR-LT-07 infected and used the fixed reproducibility seed 8213026. Propagation was simulated for up to 30 time steps. S0 (Current controls) is the baseline for calculating absolute risk reduction (ARR) and relative risk reduction (RRR).

Supplied Control Scenarios

Scenario	Control	Patch factor	Segmentation factor	Isolation delay	Post-detection factor
S0	Current controls	1.00	1.00	99	1.00
S1	Patch vendor path	0.42	1.00	99	1.00
S2	Strengthen OT segmentation	1.00	0.18	99	1.00
S3	Rapid EDR isolation	1.00	1.00	2	0.18
S4	Combined controls	0.42	0.18	2	0.18

Table C2-1: Supplied Control Scenarios

Simulation Results

Scenario	Reach OT	Reach Safety	Mean critical infected	Mean total infected	Median time to OT	P95 spread
S0 – Current controls	33.5%	10.2%	5.077	7.253	4	20
S1 – Patch vendor path	4.8%	1.5%	1.013	2.187	4	6
S2 – Strengthen OT segmentation	1.7%	0.0%	1.843	3.116	5	7
S3 – Rapid EDR isolation	21.9%	2.1%	2.887	4.428	4	13
S4 – Combined controls	0.3%	0.0%	0.606	1.659	4	5

Table C2-2: Monte Carlo Simulation Results by Scenario

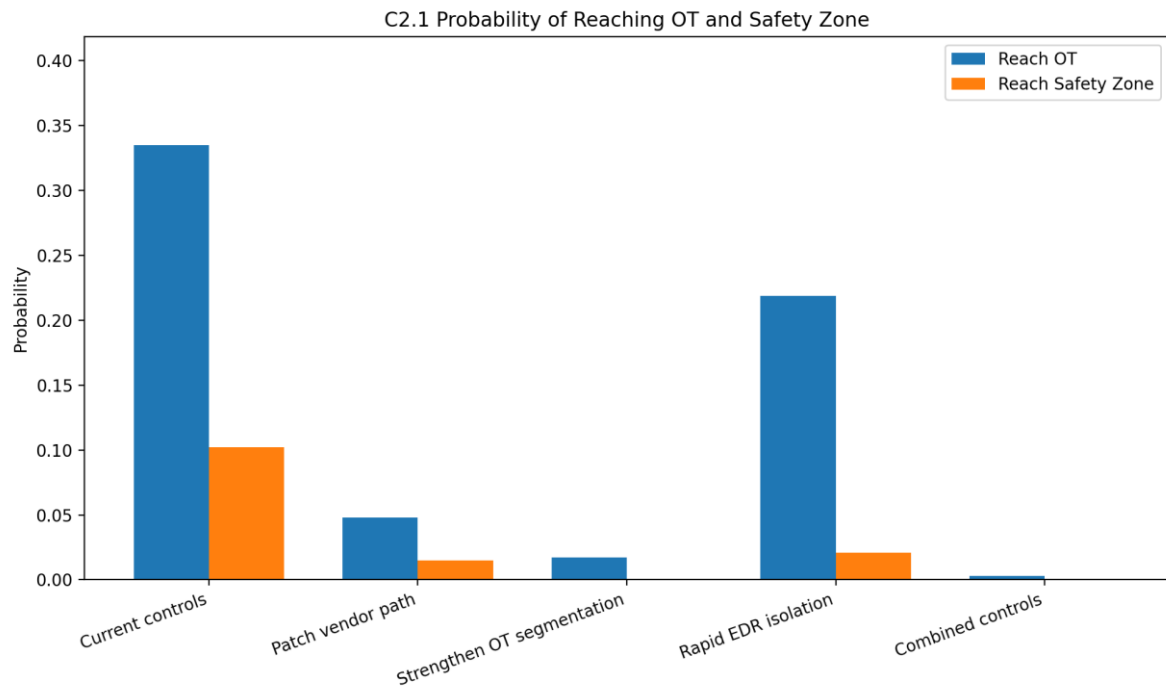


Figure C2-1: Probability of reaching OT and the Safety zone by control scenario

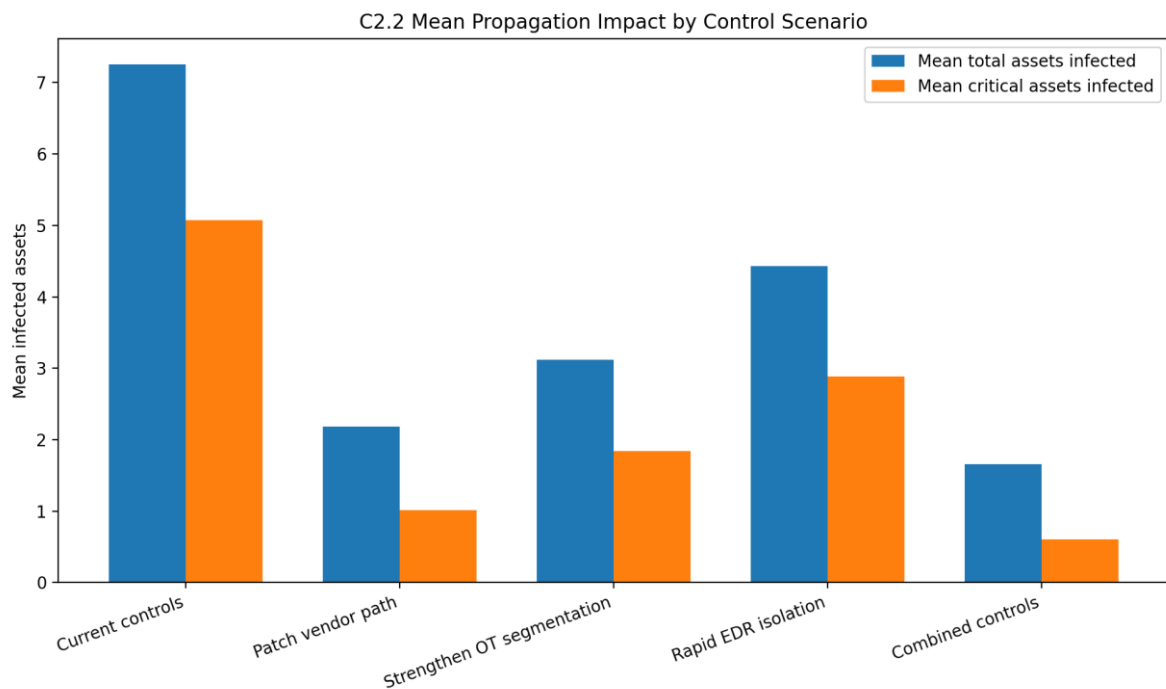


Figure C2-2: Mean critical and total assets infected by control scenario

C2.3 Risk Reduction Against Current-Controls Baseline

Scenario	OT ARR	OT RRR	Safety ARR	Safety RRR
S1 – Patch vendor path	28.7 percentage points	85.67%	8.7 percentage points	85.29%
S2 – Strengthen OT segmentation	31.8 percentage points	94.93%	10.2 percentage points	100.00%
S3 – Rapid EDR isolation	11.6 percentage points	34.63%	8.1 percentage points	79.41%
S4 – Combined controls	33.2 percentage points	99.10%	10.2 percentage points	100.00%

The calculated absolute risk reduction was calculated as the baseline probability minus the controlled probability, and relation risk reduction as that difference divided by the baseline. For OT reach, S4 lowered the detected simulation result from 33.5% to 0.3% 33.2 percentage points or 99.10% relative reduction. S2 and S4 produced no Safety-zone reaches in 1,000 runs; I interpret this as a complete reduction within this finite sample, not evidence that real-world residual risk is zero.

Key Findings

- S0: 33.5% of runs reached OT and 10.2% reached the Safety zone.
- S1: OT reach fell to 4.8% and mean total infected assets fell from 7.253 to 2.187.
- S2: OT reach fell to 1.7% and simulated Safety-zone reach was 0%.
- S3: OT reach fell to 21.9%, showing the benefit of rapid isolation, but it was weaker than S1 and S2 for OT reach in this model.
- S4: OT reach was 0.3%, Safety-zone reach was 0%, mean critical infected assets were 0.606, mean total infected assets were 1.659, and P95 spread was 5.

Model Evaluation and Control Recommendation

Data Accuracy and Model Validity

The supplied datasets are synthetic teaching data, hence transmission probabilities and susceptibility values should not be interpreted as measured real world attack probabilities. The model is suitable for relative comparison of the supplied controls because the same topology, starting condition and simulation method are applied consistently. It is not intended to predict the exact probability of a real cyberattack.

Independence Assumptions and Parameter Sensitivity

Monte Carlo iterations are treated as independent runs. Real incidents may violate this assumption because credential reuse, privilege escalation, common vulnerabilities and shared infrastructure can create dependencies. Results are sensitive to the supplied patch, segmentation and isolation factors; therefore, relative comparison is more useful than treating the percentages as exact operational probabilities.

Computational Limits

Each scenario used 1,000 iterations and a 30-step maximum horizon. More iterations could reduce sampling variation, while a more detailed model could represent additional attack stages. The present model is appropriate for a practical lab comparison rather than a full operational digital twin.

Simulated Compromise versus Operational Consequence

An infected OT or Safety asset in the simulation is not evidence of successful PLC reprogramming, process manipulation or physical safety and production impact. Operational result needs separate confirmation using OT engineering evidence, PLC/HMI records, change logs and process information.

Control Recommendation

Scenario 4 merged controls are recommended because it provides the largest simulated reduction in propagation risk. It combines vendor path patching, stronger OT segmentation and rapid EDR isolation. When comparing scenario 0 with Scenario 4 which reduces simulated OT reach by 99.10% relative risk and reduces Safety zone reach from 10.2% to 0% in the 1,000 run simulation.

The operational trade-off is that stronger separation and rapid isolation can limit legitimate vendor access or affect availability during maintenance. EGS should apply these controls through OT change management procedures, authorized maintenance windows, controlled vendor access and safety or availability checks.

Predictive Security Intelligence and Adversarial ML

Predictive Risk Model

The supplied `egs_daily_risk_training.csv` dataset includes daily security indicators and target variable incident within 7 days. The model predicts whether an incident is expected within seven days. The date field is excluded from prediction because the security indicators are the intended explanatory variables and using calendar date directly could introduce spurious time effects.

Data and Stratified Split

The dataset holds 540 daily records of which 402 negative cases and 138 are positive cases. A reproducible graded split was used with 70% training 378 rows, 15% validation 81 rows and 15% held out test 81 rows. The fixed random seed is 8213026. Layer preserves the incident or non-incident class proportions across the splits.

Classifier Selection and Justification

standardised logistic is selected regression because the predictors are numeric counts or continuous indicators and the task requires an explainable probability of an incident within seven days. Setting prevents variables with larger numeric ranges from controlling the fit. Transparent baseline is preferred over an unclear model because EGS analysts need to explain why a day was escalated and assess the cost of false negatives.

Operating Threshold

The operating threshold selected on the validation set and not the held-out test set. The thresholds evaluated from 0.10 until 0.70 and 0.31 is chosen because it met the minimum 75% recall requirement while giving the best precision among qualifying thresholds. This reflects decision to favour earlier warning in a critical infrastructure setting while still limiting pointless analyst workload.

Test-set Evaluation

Metric	Result
Operating threshold	0.31
Confusion matrix	[[54, 7], [4, 16]]
Accuracy	0.8642 (86.42%)
Precision	0.6957 (69.57%)
Recall	0.8000 (80.00%)
F1-score	0.7442 (74.42%)
False-negative rate	0.2000 (20.00%)
ROC-AUC	0.9352

Table D1-1: Predictive Risk Model Test-Set Evaluation

The threshold which selected held-out test set produced 16 true positives with 54 true negatives, 7 false positives and 4 false negatives. The model therefore detects 80.00% of the incident days in the test set, with a false-negative rate at 20.00%.

Why Recall Matters for Proactive Critical Infrastructure Defence

Recall is very important because a false negative represents an incident risk day that the model fails to flag. In critical infrastructure if an early warning is missed that can delay investigation, containment and protective action which end up allowing a developing attack to progress.

The lower threshold of 0.31 intentionally favours earlier detection. On the held-out test set, it has generated 23 alerts out of 81 test days 28.4% compared with 18 alerts at the conventional 0.50 threshold. It also reduced false negatives from 5 at 0.50 to 4 at the selected threshold. The trade-off is a higher false positive burden, hence alerts should be prioritised by criticality, corroborated with other telemetry and handled through analyst triage instead of treated as confirmed incidents.

Risk Escalation and Incident Correlation

Investigation Risk Scoring

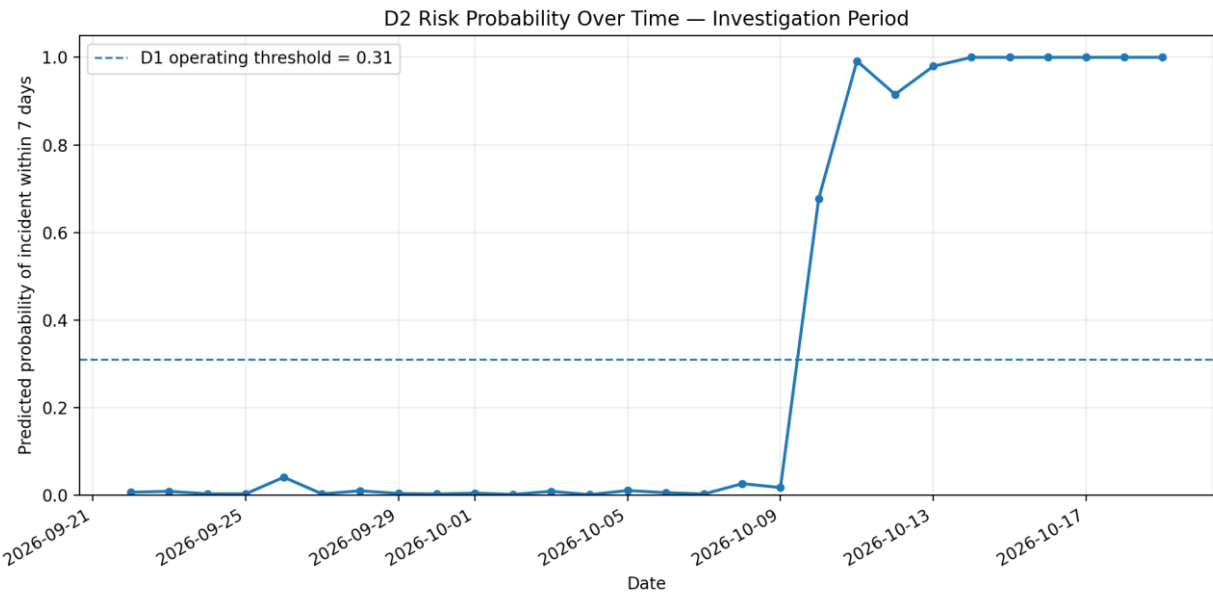
The highest risk period begins on 10 October 2026. The ten highest scored days are concentrated from 10 to 19 October, showing a sustained escalation rather than an isolated high score.

Rank	Date	Risk probability	Flagged at 0.31
1	2026-10-17	100.0000%	Yes
2	2026-10-16	100.0000%	Yes
3	2026-10-19	100.0000%	Yes
4	2026-10-15	100.0000%	Yes
5	2026-10-18	99.9999%	Yes

6	2026-10-14	99.9996%	Yes
7	2026-10-11	99.1551%	Yes
8	2026-10-13	97.9592%	Yes
9	2026-10-12	91.5510%	Yes
10	2026-10-10	67.7186%	Yes

Table D2-1: Top Ten Investigation Risk Days

Risk Probability Over Time and Escalation Point



Earliest defensible escalation point: 10 October 2026 the predicted risk rises from 1.74% on 9 October to 67.72% on 10 October, crossing the 0.31 operating threshold with wide margin. It then remains above the threshold for every subsequent investigation day through 19 October. Therefor this makes 10 October the earliest defensible point for enhanced investigation and containment preparation while the later evidence of 17 October provides direct corroboration.

Concise Cross-Source Incident Timeline

Timestamp	ID	Type	Observed action	Analytical interpretation
2026-10-14	RPT9001	Report	Kalahari Jackal vendor remote-access campaign; compromised maintenance vendors, MFA prompts, RDP and PowerShell.	Threat context consistent with the later vendor-access sequence; intelligence is contextual, not proof.
2026-10-14	IOC9005	IOC	maintenance-check.example; medium-confidence credential-harvesting domain.	Supports phishing/credential-access context; requires internal validation.
2026-10-15	RPT9002	Report	Sandstorm Loader C2 uses periodic DNS to desert-sync.example and TLS to 198.51.100.44.	Directly relevant to the later DNS/C2 indicators.
2026-10-16	IOC9001	IOC	203.0.113.77; high-confidence vendor access infrastructure.	Matches the external source in the suspicious VPN sequence.

2026-10-16	IOC9002	IOC	desert-sync.example; high-confidence Sandstorm Loader C2 domain.	Matches EVT01578 beaconing.
2026-10-16	IOC9004	IOC	Sandstorm Loader SHA-256; high confidence.	Matches the malware named in EVT01577.
2026-10-16	RPT9003	Report	Current campaign includes movement to engineering workstations, Modbus reconnaissance and attempted register writes; no destructive effect where filtering is active.	Provides context for the OT scan/write attempt and supports a cautious impact conclusion.
2026-10-17 19:42:10	EVT01574	Event	VPN login failure from 203.0.113.77; MFA rejected.	Initial suspicious vendor-path access attempt.
2026-10-17 19:42:46	EVT01575	Event	Repeated VPN login failure from 203.0.113.77.	Strengthens attempted-intrusion assessment.
2026-10-17 19:43:18	EVT01576	Event	Successful vendor login from new device after MFA approval.	Successful access to the vendor remote-access path.
2026-10-17 19:47:03	EVT01577	Event	Unsigned sandstorm-loader.bin launched PowerShell on VENDOR-LT-07.	Endpoint execution evidence consistent with IOC9004/RPT9004.
2026-10-17 19:49:12	EVT01578	Event	Periodic DNS query to desert-sync.example.	C2 beaconing consistent with IOC9002.
2026-10-17 19:51:40	EVT01579	Event	RDP session through vendor path from IOC9001 source.	Lateral movement evidence.
2026-10-17 20:03:15	EVT01580	Event	vendor_maint authenticated to OT-JUMP-01 outside approved window.	Successful OT jump-host access is confirmed.
2026-10-17 20:08:31	EVT01582	Event	Unexpected RDP access to ENG-WS-01.	Successful engineering-workstation access is confirmed.
2026-10-17 20:11:09	EVT01583	Event	Sequential scan of PLC subnet using Modbus/502.	OT reconnaissance is confirmed.
2026-10-17 20:18:02	EVT01586	Event	Modbus function 16 register-write attempt blocked by OT firewall.	Control-system manipulation was attempted but successful manipulation is not confirmed.
2026-10-17 20:24:10	EVT01588	Event	Outbound connection to 198.51.100.44 blocked by OT egress policy.	C2 path was blocked at this point.
2026-10-17 20:28:03	EVT01589 / EVT01590	Event	SOC isolated OT-JUMP-01 and terminated the vendor VPN session.	Containment action; supports that the suspicious sequence was actively disrupted.

Table D2-2: Concise Cross-Source Incident Timeline

The timeline contains 16 distinct event IDs and 7 intelligence/report/IOC IDs, exceeding the minimum requirement. Evidence IDs are retained so each conclusion can be traced back to the supplied records.

Evidence-Based Incident Assessment

Assessment	Status	Evidence-based conclusion	Key evidence
------------	--------	---------------------------	--------------

Attempted intrusion	CONFIRMED / HIGH CONFIDENCE	Failed VPN logins followed by a successful login from IOC9001 infrastructure, malicious endpoint execution, C2 DNS, RDP/lateral movement and OT reconnaissance.	EVT01574–EVT01584; IOC9001–IOC9004; RPT9001–RPT9005
Successful OT access	CONFIRMED, LIMITED SCOPE	The vendor account successfully authenticated to OT-JUMP-01 and reached ENG-WS-01.	EVT01580; EVT01582
Successful control-system manipulation	NOT CONFIRMED	A Modbus register-write was attempted but was explicitly blocked by the OT firewall. There is no supplied evidence of a successful PLC state change.	EVT01586; RPT9003
Operational impact	NOT CONFIRMED	The supplied records show containment and blocked OT/C2 actions, but no evidence of production disruption, safety impact, outage or successful process-state change.	EVT01586; EVT01588–EVT01590; supplied event log

Table D2-3: Evidence-Based Incident Assessment

Adversarial Robustness and Governance

Objective. The D3 assessment scores the supplied adversarial risk variants using the same standardised logistic-regression risk model developed in D1. The purpose is to determine whether changes in telemetry patterns can reduce the model’s estimated risk and therefore weaken detection or prioritisation.

Method. The D1 model was retrained using the fixed seed 8213026 and the same feature set. Each adversarial case was scored using the model probability of incident_within_7d. The D1 operating threshold of 0.31 was retained for comparison.

Adversarial variant results

Case	Variant	Risk probability	Change vs baseline	Assessment
AR01	baseline_attack	100.00%	0.00 pp	Baseline
AR02	low_and_slow	89.28%	–10.72 pp	Largest reduction
AR03	distributed_sources	99.83%	–0.17 pp	Minimal reduction
AR04	living_off_the_land	99.99%	–0.01 pp	Minimal reduction
AR05	suppressed_telemetry	93.89%	–6.11 pp	Second-largest reduction

Table D3-1: Adversarial Variant Risk Results

Interpretation. The baseline attack produced an almost certain risk score (100.00%). The low-and-slow variant reduced the score to 89.28%, a 10.72 percentage-point decrease, while suppressed telemetry reduced it to 93.89%. Distributed sources and living-off-the-land produced only very small reductions. All five variants remained above the 0.31 operating threshold, so none would be classified as low risk by the selected threshold. However, the reductions show that adversarial behaviour can weaken prioritisation and could become more serious when combined with additional feature manipulation.

How adversarial behaviour can weaken detection

Low-and-slow activity: Spreads malicious activity over longer periods and reduces event counts. This can make failed logins, DNS activity, EDR alerts and OT scans resemble normal background activity, as demonstrated by AR02.

Feature manipulation: An attacker can deliberately reduce or alter the telemetry features used by the model for example by avoiding repeated authentication failures, limiting OT scans or reducing observable EDR activity. This can force the probability downward even when the underlying target remains malicious.

Obfuscated threat language: Threat reports or analyst facing text can be rewritten with vague, indirect or benign sounding language. A text model may then receive fewer security relevant terms and under rank the report.

Poisoned training data: If malicious or deliberately manipulated examples enter the training set with incorrect labels, the model will learn that harmful behaviour which is normal. Hence that can reduce future detection performance and make evaluation results look reliable than the model's real world performance.

Model drift: Normal operational behaviour and attacker techniques change over time. A model trained on older patterns may therefore become poorly calibrated which increasing false negatives or false positives except it is monitored and periodically revalidated.

Recommended technical and governance controls

1. Data-quality and poisoning controls: Maintain provenance for training data, validate labels, use controlled data ingestion, investigate anomalous training records and keep immutable audit logs.

2. Adversarial validation and red-team testing: Regularly test low-and-slow, distributed, telemetry-suppression and feature-manipulation variants before deploying or updating the model.

3. Drift monitoring and recalibration: Monitor feature distributions, alert rates and model performance over time. Revalidate and recalibrate thresholds when operational behaviour changes.

4. Multi-source detection and rule-based safeguards: Do not rely on the model alone. Correlate identity, VPN, EDR, DNS, OT-IDS and firewall evidence and retain high-confidence rules for critical behaviours.

5. Human analyst review for critical OT alerts: Require analyst validation and contextual investigation for high-risk OT events so a manipulated model score cannot by itself suppress a potentially serious incident.

Executive Intelligence Brief

To: Chief Operations Officer and Chief Information Security Officer

Subject: Vendor-to-OT intrusion assessment and immediate risk decision

Assessment date: 19 October 2026

EGS experienced an unauthorised intrusion attempt through the vendor remote-access pathway, with confirmed access to OT-JUMP-01 and ENG-WS-01. Evidence also confirms suspicious loader execution, OT reconnaissance and a blocked Modbus register-write attempt. Successful PLC manipulation, process change and operational impact are not confirmed.

Scope, campaign and warning

Pathway: external source → VPN-GW-01 → VENDOR-DMZ-01 → OT-JUMP-01 → ENG-WS-01 → PLC subnet. Confirmed access affected OT-JUMP-01 and ENG-WS-01, while VENDOR-LT-07 was the source endpoint on which the suspicious loader executed. PLC-SUB-01 was scanned and targeted by a blocked Modbus register-write attempt; the Safety system was not reached. The activity aligns with the supplied Kalahari Jackal and Sandstorm Loader campaign (RPT9001–RPT9004; IOC9001–IOC9003). Predictive risk crossed the 0.31 threshold on 10 October, before the 17 October event sequence, and remained elevated through 19 October.

Simulation based risk

Current controls allowed OT reach at 33.5% of simulated runs and Safety-zone reach at 10.2%. The combined package vendor path patching, stronger OT segmentation and rapid isolation reduced observed OT reach to 0.3% and produced no Safety-zone reaches in 1,000 runs. These outcomes support prioritisation not a promise of zero residual risk.

Key limitations

External IOCs, model probabilities and synthetic simulation parameters are decision support evidence not evidence. Persistent access, data exfiltration, PLC state change, safety impact as well as service disruption remain unconfirmed.

Priority actions

- 1. Contain:** Keep the affected vendor path suspended while review credentials, MFA and device trust and preserve VENDOR-LT-07, OT-JUMP-01 and ENG-WS-01 for investigation.
- 2. Reduce exposure:** Implement vendor-path patching also tighter OT segmentation and rapid endpoint isolation through approved OT change control.
- 3. Detect:** Correlate VPN, identity, EDR, DNS, firewall and OT telemetry must be monitored model drift and require analyst validation for high impact OT decisions.

Decision required

Approve continued suspension of the vendor access path until credential review, endpoint forensics and PLC or historian validation determine whether credentials were compromised, process or configuration state changed.

Unresolved intelligence requirement and 90-day measure

Unresolved requirement: Were vendor credentials or tokens compromised and did any PLC or historian state change? **90-day measure:** Achieve at least 95% compliance for approved maintenance windows, MFA, trusted devices and current security posture with monthly reporting and tracked isolation time.